

Laundering by Secure Aggregation: Temporal Group Testing for Byzantine-Robust Federated Learning with Code-Based Post-Quantum Confidentiality

Md Wahiduzzaman Suva and Esm-e Moula Chowdhury Abha

Abstract—Secure aggregation reveals only the sum of federated learning (FL) updates. Its key establishment breaks under a quantum adversary. Post-quantum FL today rests almost entirely on lattice assumptions. We identify a *laundering* effect. Aggregating securely within clusters of c clients turns amplified sign-flip poisoning into inverted cluster sums of plausible magnitude. Every coordinate-wise robust rule applied across those sums is defeated. We introduce CB-SAFE+. It re-randomizes the clustering each round. It accumulates per-client suspicion from root-anchored direction flags, a form of temporal group testing over private sums. Attackers the server never observes individually are excluded. Only the cluster sums already revealed are used. A simulation-based privacy theorem bounds what this discloses. We also quantify the tension it manages. The anonymity set grows with c . The probability that a cluster sum stays clean decays as $(1 - f)^c$. We instantiate the framework over a code-based KEM. HQC was selected by NIST in March 2025. To our knowledge this is the first Bonawitz-style masked FL aggregation built on a code-based rather than a lattice KEM. The KEM is pluggable and affects only setup. On a 291498-parameter model with 30 clients, per-round traffic is KEM-independent. The full code-based premium is a one-time 15.2 versus 3.8 KiB per masking partner at NIST level 1. That is under 0.03% of training traffic. Fixed clusters give each client $c - 1$ partners, so setup is constant in population. CB-SAFE+ instead needs secrets with all peers. Its one-time setup is therefore $O(N)$, while its per-round cost stays $O(c)$. We evaluate on CIFAR-10, FashionMNIST, EMNIST, and tabular Edge-IIoTset. The laundering effect and CB-SAFE+'s recovery replicate on every dataset. CB-SAFE+ beats every baseline under sign-flip in a pooled paired test (Holm-corrected $p < 0.01$). CB-SAFE+ targets untargeted poisoning. A patch-trigger backdoor evades its direction and loss tests. We scope that limit out rather than claim it.

Index Terms—Post-quantum cryptography, federated learning, secure aggregation, HQC, code-based cryptography, Byzantine robustness, cryptographic diversity.

I. INTRODUCTION

FEDERATED learning (FL) trains a shared model across many clients without centralizing data [26], [27], but the transmitted model updates leak private information: gradient-inversion [28], [29] and membership- or model-inversion [30], [31] attacks reconstruct training samples from individual updates. Secure aggregation closes this channel by ensuring the server observes only the *sum* of updates, using pairwise

additive masks that cancel on aggregation [1], [14]; recent designs reduce its overhead [33], [34], though the sum itself can still leak [32]. The confidentiality of those masks rests on key establishment that Shor's algorithm [35] breaks once a cryptographically relevant quantum computer exists, and traffic recorded today can be decrypted then ("harvest-now, decrypt-later").

The standard response replaces classical key exchange with a post-quantum KEM, and nearly all post-quantum FL does so with *lattice* cryptography [4]–[7], [19]. Lattices are efficient and standardized (ML-KEM, FIPS 203 [3]), but concentrating an entire ecosystem's confidentiality on one hardness assumption is a systemic risk: a single cryptanalytic advance would break every such deployment simultaneously. NIST recognized exactly this risk when, in March 2025, it *selected* the code-based KEM HQC [59] (whose security reduces to syndrome decoding of quasi-cyclic codes [37], not to lattice problems, in the tradition of code-based cryptography since McEliece [36]) as a diversified backup to ML-KEM [2]. That diversity has not reached federated learning.

A second, orthogonal tension is that secure aggregation and Byzantine robustness pull in opposite directions: hiding individual updates denies the server exactly the visibility that poisoning defenses need. Recent work combines robustness with *lattice*-based post-quantum aggregation [7], or achieves cluster-based robust aggregation on *quantum hardware* [8]; no prior framework provides both under a code-based, classical post-quantum assumption.

This paper presents CB-SAFE (Code-Based Secure Aggregation for Federated Learning), making five contributions:

- 1) A KEM-agnostic secure-aggregation protocol (Definition 1) that formalizes Bonawitz-style double masking over any IND-CCA2 KEM. Per-round mask seeds are derived from long-lived encapsulated secrets, so key encapsulation is a one-time cost. The post-quantum primitive becomes a single replaceable module.
- 2) A code-based instantiation, scope-qualified. To our knowledge, CB-SAFE is the first FL secure-aggregation framework to obtain post-quantum confidentiality by substituting the *key-establishment* KEM in Bonawitz-style pairwise masking with the NIST-selected code-based HQC, at matched NIST security levels. Code-based secure aggregation as such is not new. Prior work [9] reaches it through LPN-based homomorphic encryption. We therefore claim only the KEM route. Its distinguishing property is that the code-based premium stays a one-time setup cost.

M. W. Suva (ID 26-94088-2) and E. M. C. Abha (ID 26-94089-2) are with the Department of Computer Science, American International University-Bangladesh, Dhaka, Bangladesh. Corresponding author: M. W. Suva (e-mail: 26-94088-2@student.aiub.edu; 26-94089-2@student.aiub.edu).

Manuscript prepared September 2026. Source code, all result CSVs, and the scripts that regenerate every table and figure are available at <https://github.com/wshuv-o/cb-safe-draft>.

- 3) A quantified reconciliation of privacy and robustness. Secure aggregation runs *within* clusters of c clients. Robust aggregation (trimmed mean, median, Multi-Krum) runs *across* the cluster sums. An explicit trade-off law relates the two: the anonymity set is c , while the clean-cluster probability decays as $(1 - f)^c$. We validate it experimentally under three attacks. We further identify and analyze a *laundering* effect. Cluster averaging turns amplified sign-flip poisoning into direction-inverted cluster sums of plausible magnitude. These defeat every coordinate-wise robust rule (Proposition 1).
- 4) CB-SAFE+, a defense that identifies hidden attackers. Per-round re-randomized clustering and direction flags against a small server root dataset accumulate per-client suspicion. This is temporal group testing over privacy-preserving observations. It excludes malicious clients the server has never observed individually. The flags are post-processing of already-revealed cluster sums. The defense therefore adds *no* update-content leakage beyond CB-SAFE itself (Theorem 1).
- 5) A measured cost analysis. On a 291k-parameter model, per-round traffic is KEM-independent. The full code-based premium is a one-time 15.2 KiB against 3.8 KiB per client at NIST level 1. That is 0.7% of one round's traffic and under 0.03% amortized over training. HQC's key generation is about $100\times$ slower at NIST level 1. It contributes roughly 2 s once for all 30 clients, against 0.02 s for ML-KEM.

Taken together, these contributions separate two questions that the literature usually answers at once. The first is what a post-quantum secure-aggregation protocol costs once the KEM is treated as a replaceable module. The second is what robustness survives when the server is allowed to see only cluster sums. Our answer to the first is that the cost is a one-time setup constant. Our answer to the second is less comfortable: privacy-preserving aggregation actively launders a standard poisoning attack, and recovering from it requires a detector built for the constraint rather than a robust rule borrowed from the plaintext setting. The rest of the paper develops both answers and reports where each stops holding.

II. RELATED WORK

1) *Secure aggregation*: Masking-based secure aggregation lets an honest-but-curious server learn only the *sum* of client updates. Bonawitz *et al.* [1] cancel pairwise one-time masks and tolerate dropout through secret-shared seeds; subsequent work drives down the quadratic overhead with (poly)logarithmic-round constructions [14], coded and one-shot recovery (LightSecAgg [33], SwiftAgg [34]), and single-server multi-round aggregation that removes the per-round setup (Flamingo [55]). This entire line shares one property we must contend with: by construction the server sees only the aggregate—which can itself still leak [32]—and never the per-client updates that Byzantine defenses rely on. Our masked-aggregation layer follows the same double-masking template but factors key establishment behind a KEM-agnostic interface, so a code-based post-quantum KEM substitutes for the classical one in a single module.

2) *Post-quantum federated learning*: PQSF reconstructs masks with lattice multi-stage secret sharing [4]; Qin and Xu build single-round aggregation from a lattice key-homomorphic PRF [5]; Narsimhulu *et al.* aggregate Dilithium-style lattice signatures [6]; and a 2026 framework combines reputation-weighted Byzantine-robust aggregation with Kyber/lattice-based secure aggregation for IoT threat intelligence [7]. Surveys confirm lattice dominance across post-quantum deployment [19]. Non-lattice exceptions are few: multivariate cryptography with blockchain [11], and CQSA, which partitions clients into clusters aggregated via GHZ states on near-term *quantum hardware* [8]. Code-based constructions are not absent, however. Closest is [9], which builds secure aggregation from key- and message-additive homomorphic encryption under Learning Parity with Noise and treats the multi-round FL setting explicitly. That work and ours reach code-based confidentiality by different routes: it replaces the aggregation primitive with an LPN-based homomorphic scheme, whereas we keep Bonawitz-style pairwise masking and replace only the key-establishment KEM, which is what lets the same protocol run unchanged over HQC or ML-KEM and makes the code-based premium a one-time setup cost rather than a per-round one. Our claim is therefore scoped to the KEM route, not to code-based secure aggregation in general. CB-SAFE differs from the lattice work on the confidentiality assumption: syndrome decoding of quasi-cyclic codes, via a standard-track classical KEM [2], with the KEM exposed behind an agnostic interface so lattice and code-based variants differ in exactly one module.

3) *Byzantine robustness and poisoning*: Model- and data-poisoning attacks [23], [24], [41], including stealthy [39] and backdoor [17], [40] variants, and their defenses are a large literature: robust aggregation rules such as Multi-Krum [15], coordinate-wise trimmed mean and median [16], Bulyan [21], and the geometric-median aggregator RFA [22]; trust-bootstrapped filtering (FLTrust [12], Zeno [13]); malicious-client detection, including recent 2025–26 methods (FLDetector [42], FLAegis [52], SafeFL [53], and loss-trend monitoring [54], whose temporal-loss signal parallels our root-loss probe); and backdoor-specific defenses (FLAME [25]). These detectors inspect *individual* client updates, which secure aggregation deliberately hides. A parallel line enforces robustness or integrity *on the masked updates themselves*—zero-knowledge norm and well-formedness proofs (RoFL [56]), verifiable secret-shared integrity checks (EIFFeL [57]), and two-server distributed-trust aggregation that withstands malicious clients (ELSA [58])—but these are classical (pre-quantum) and *bound or validate* updates rather than identifying the responsible clients. Privacy-preserving robust aggregators narrow that gap (PriRoAgg [50], Giskard [51]), but obtain confidentiality from lattice/MPC rather than a post-quantum code-based KEM and do not identify individual attackers. This is the privacy–robustness–post-quantum tension we address.

4) *Cluster-based robust aggregation*: Reconciling Byzantine resilience with secure aggregation is an established goal: BREA does so through secret-shared distance computation [18], CQSA through clustered aggregation on quantum hardware [8], and, closest to our robustness mechanism, FedGT

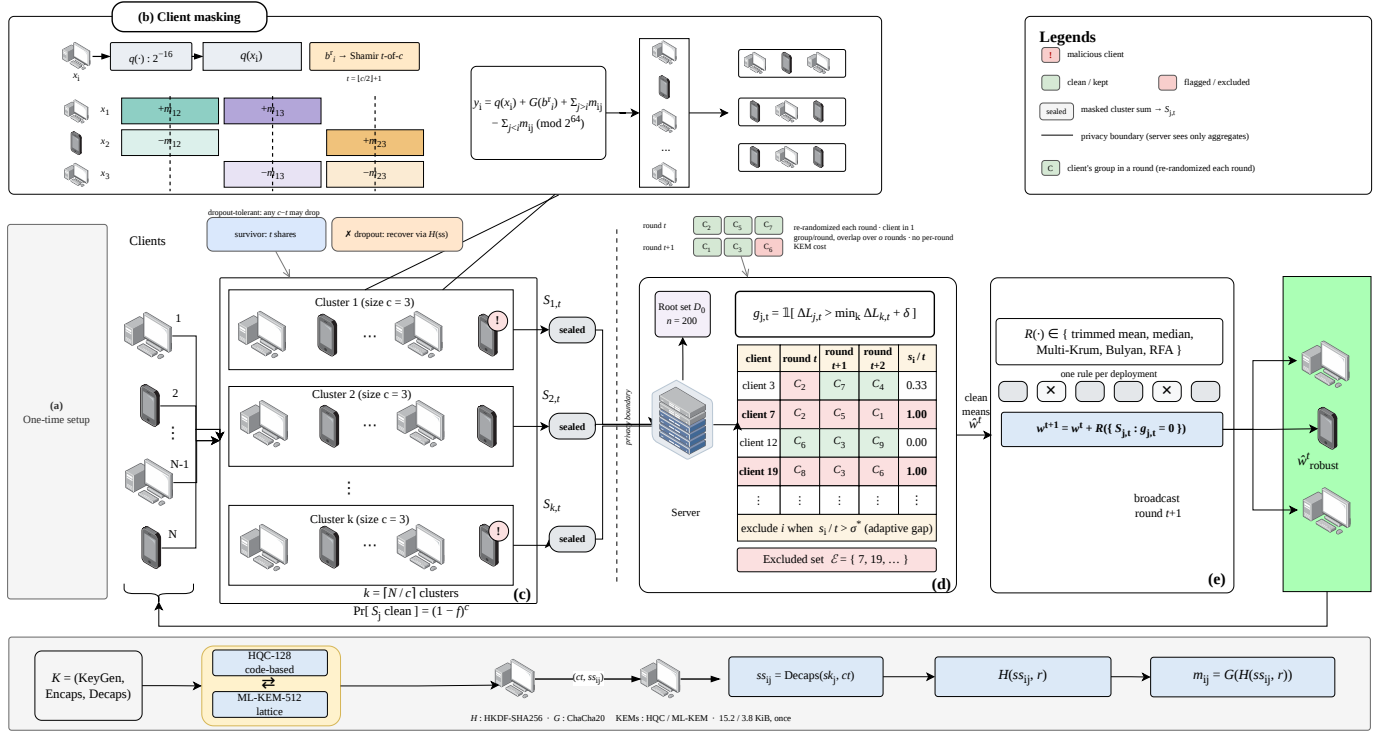


Fig. 1. CB-SAFE, one training round end to end: one-time HQC key setup, within-cluster masked aggregation (the server sees only the k cluster sums), and the CB-SAFE+ flag/exclude stage.

[20] identifies malicious clients by non-adaptive group testing [43], [44] over overlapping secure-aggregation groups, decoding a fixed parity-check assignment with a per-round BCJR decoder [63] whose code is designed for a small, fixed population ($n \leq 31$). Aggregating within groups and inspecting group sums is thus a known structure; our contribution is not the cluster topology itself but (i) its first classical post-quantum, code-based instantiation and (ii) an explicit, experimentally validated statement of the privacy-robustness trade-off it induces (Section III-D), with a temporal group-testing defense (CB-SAFE+) that matches FedGT's attacker identification at far lower false-positive cost, and scales past FedGT's fixed small-population design.

Across this landscape, existing post-quantum FL is lattice-based and, with one recent exception [7], not Byzantine-robust; classical robust-aggregation and detection methods are neither post-quantum nor compatible with secure aggregation; and FedGT—the closest design—is neither post-quantum nor scalable beyond its fixed $n \leq 31$ code. CB-SAFE+ is, to our knowledge, the only framework that is simultaneously code-based post-quantum, secure-aggregating, Byzantine-robust, identifies malicious clients, and scales.

III. THE CB-SAFE FRAMEWORK

A. Notation

We use lowercase bold for vectors and uppercase bold for matrices. The server coordinates N clients grouped into clusters of size c ; a fraction f is malicious.

B. System and Threat Model

A server coordinates N clients running FedAvg over non-IID data partitions. Clients are partitioned into $k = \lceil N/c \rceil$ clusters of size c . The server is honest-but-curious; a fraction f of clients are malicious and submit poisoned updates; clients may drop out mid-round. Within a cluster, mask recovery uses a t -of- c threshold with $t = \lfloor c/2 \rfloor + 1$, so privacy holds against the server colluding with up to $t - 1$ members of a cluster, and any $c - t$ members can drop without stalling the round. Update authentication is out of the code-based scope: HQC cannot sign and no code-based signature is standardized, so where signatures are required we compose the lattice-based ML-DSA [38] and state explicitly that only the confidentiality layer is code-based.

C. KEM-Agnostic Masked Aggregation

Definition 1 (KEM-agnostic cluster masking): Let $K = (\text{KeyGen, Encaps, Decaps})$ be an IND-CCA2 KEM, H a key-derivation function, and G a PRG into $(\mathbb{Z}_{2^{64}})^d$. At setup, each client i publishes pk_i ; for each cluster pair $i < j$, client i computes $(ct_{ij}, ss_{ij}) = \text{Encaps}(pk_j)$ and j recovers $ss_{ij} = \text{Decaps}(sk_j, ct_{ij})$. In round r , client i quantizes its update x_i to $q(x_i) \in (\mathbb{Z}_{2^{64}})^d$, draws a self-mask seed b_i^r , Shamir-shares it t -of- c within its cluster, and submits

$$y_i = q(x_i) + G(b_i^r) + \sum_{j > i} G(H(ss_{ij}, r)) - \sum_{j < i} G(H(ss_{ij}, r)) \mod 2^{64}, \quad (1)$$

Algorithm 1: Cluster Secure Aggregation (round r)

Input: cluster C of size c , threshold t , per-pair secrets $\{ss_{ij}\}$
Output: cluster sum $\sum_{i \in \text{alive}} q(\mathbf{x}_i)$
foreach client $i \in C$ **do**
 $q(\mathbf{x}_i) \leftarrow$ quantize local update
 draw self-mask seed b_i^r ; Shamir t -of- c share it to peers
 send masked $\mathbf{y}_i$ by Eq. (1)
 $Y \leftarrow \sum_{i \in \text{alive}} \mathbf{y}_i$ // pairwise masks cancel
foreach survivor i **do**
 reconstruct b_i^r from t shares; $Y \leftarrow Y - G(b_i^r)$
foreach dropout d **do**
 survivors reveal $H(ss_{dj}, r)$; remove orphaned mask halves from Y
return Y

where the sums run over the cluster peers of i . The server adds each cluster's submissions (pairwise masks cancel), reconstructs each survivor's b_i^r from t shares and removes $G(b_i^r)$; for a dropped client d , each survivor j reveals the per-round seed $H(ss_{dj}, r)$ and the server removes the orphaned mask halves. The server thus obtains exactly $\sum_{i \in \text{alive}} q(x_i)$ per cluster.

Correctness is exact: masking is modular-arithmetic exact, and the only deviation from plain float aggregation is fixed-point quantization (2^{-16} per coordinate). Because encapsulation happens once and per-round seeds come from $H(ss_{ij}, r)$, per-round messages contain no KEM material at all: the masked update is $8d$ bytes regardless of the KEM, and the KEM's key and ciphertext sizes appear only in the one-time setup. Instantiating $\mathcal{K}$ with HQC gives the code-based variant; with ML-KEM [3], the lattice baseline.

Theorem 1 (Privacy against honest-but-curious coalitions): Assume $\mathcal{K}$ is IND-CCA2, H is a secure KDF, and G is a secure PRG. Fix a cluster C of size c with threshold $t = \lfloor c/2 \rfloor + 1$, and let the adversary $\mathcal{A}$ comprise the honest-but-curious server and any statically chosen $T \subset C$ with $|T| \leq t - 1$ (the corruption set is fixed before the protocol runs; we do not claim adaptive-corruption security). There exists a PPT simulator that, given only the corrupted clients' inputs and the sum $\sum_{i \in \text{alive}(C) \setminus T} q(x_i)$, produces a view computationally indistinguishable from $\mathcal{A}$'s view of a CB-SAFE round. The CB-SAFE+ flag bits are a deterministic function of the revealed cluster sums and server-local data, so CB-SAFE+ leaks nothing beyond CB-SAFE.

Proof sketch. A hybrid argument. (H1) Replace each pairwise secret ss_{ij} between honest clients by a uniform string: distinguishing H1 from the real game breaks IND-CCA2 of $\mathcal{K}$. (H2) Replace the per-round seeds $H(ss_{ij}, r)$ and mask streams $G(\cdot)$ by uniform: breaks the KDF/PRG. In H2 every honest submission y_i is uniform subject to the alive-honest submissions summing to the revealed cluster sum, which the simulator can sample directly. Shamir shares held by $\leq t - 1$ corrupted parties are uniform by perfect secrecy below the threshold, and a dropped client's revealed seeds $H(ss_{dj}, r)$ are

independent of other rounds' seeds under the KDF assumption, so both recovery paths are simulatable. Distinct rounds use distinct seeds, so views compose across rounds. $\square$

The anonymity set of an honest client is therefore its cluster's alive honest-member count, and re-randomizing the partition each round (CB-SAFE+) does not change the per-round argument because each round reveals sums of fresh, independently masked updates.

1) *Scope of the theorem.* Three limits deserve stating plainly, because the per-round guarantee is weaker than it may read.

(i) *Cross-round composition.* Masks are independent across rounds, but *updates* are not: a client trains on the same local data every round, so its contributions are strongly correlated. Over R rounds CB-SAFE+ places that client with different partners each time, so the server observes R different c -party sums each containing an approximately repeated vector. That is the same linear-system structure the fixed-cluster design refuses within a round, spread across rounds. CB-SAFE+ is itself evidence that it carries signal: the defense works precisely by inferring a per-client property (maliciousness) from cross-round group sums, and the same channel is open to an honest-but-curious server pursuing other per-client properties. The correct statement is therefore narrower than "no privacy is spent": CB-SAFE+ reveals no update *content* beyond the cluster sums CB-SAFE already exposes, but re-randomizing those sums over time is deliberately informative about individual clients. Quantifying what else is recoverable that way is open.

(ii) *The server chooses the partition.* Our anonymity-set argument assumes the partition is drawn honestly. A curious server colluding with one client can instead place that colluder with a target every round, reducing the target's effective anonymity set to the remaining $c - 2$ honest members — one, at $c=3$. Making the partition verifiably random (a shared randomness beacon, or a VRF over a public seed) closes this and is compatible with the protocol as specified; we assume it rather than implement it.

(iii) *The anonymity set is small.* At $c=3$ the server sees sums of three updates, or two with one colluder. Gradient-inversion attacks [28] are known to succeed on aggregates of this size, so "sums rather than updates" should not be read as strong protection at small c . We do not run an inversion attack on the revealed cluster sums; doing so would turn the privacy side of the privacy-robustness dial into a measured quantity rather than an asserted one, and is the experiment we would add next.

D. Robust Aggregation Across Cluster Sums

The server sees k cluster sums $S_1, \dots, S_k$ (means after dividing by alive counts) and no individual update. CB-SAFE applies a robust rule across the cluster means: coordinate-wise trimmed mean (trim β per side) or median [16], Multi-Krum [15], Bulyan [21], or the geometric median (RFA) [22]. This resolves the hide-versus-inspect tension structurally (privacy is enforced below the cluster boundary, robustness operates above it) at a quantifiable price. A cluster mean is

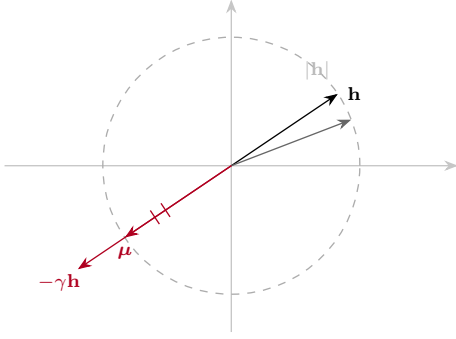


Fig. 2. Laundering geometry (schematic). Averaging $c-m$ honest updates $\mathbf{h}$ with m sign-flips $-\gamma\mathbf{h}$ gives $\boldsymbol{\mu} = \frac{c-m(1+\gamma)}{c}\mathbf{h}$; at $\gamma^*=2c/m-1$ it matches $|\mathbf{h}|$ with opposite sign (Proposition 1).

contaminated if it contains at least one malicious member, so with malicious fraction f and random cluster assignment,

$$\Pr[\text{cluster clean}] = (1-f)^c, \quad (2)$$

and the expected number of clean cluster means is $k(1-f)^c$. Larger c improves privacy (bigger anonymity set) but shrinks the clean fraction the robust rule can rely on; a trimmed mean discarding β per side tolerates at most $\lfloor \beta k \rfloor$ contaminated clusters. c is therefore a tunable privacy–robustness dial, and Section IV traces its consequences empirically. Setting $c=1$ recovers classical (privacy-free) robust aggregation; setting $c=N$ recovers full secure aggregation with no robustness.

The contamination probability, however, understates the problem: cluster averaging also *disguises* what it contaminates.

Proposition 1 (Laundering by cluster averaging): Let each honest update be $\mathbf{h}$ (up to noise) and let m members of a cluster of size c submit the scaled sign-flip $-\gamma\mathbf{h}$. The cluster mean is

$$\boldsymbol{\mu} = \frac{c-m(1+\gamma)}{c}\mathbf{h}, \quad (3)$$

whose magnitude equals an honest cluster's, $|\boldsymbol{\mu}| = |\mathbf{h}|$, exactly at

$$\gamma^* = \frac{2c}{m} - 1, \quad (4)$$

while its direction is inverted. At the common attack setting $\gamma=5$ with $c=3$, $m=1$ this holds with equality: the poisoned cluster sum is indistinguishable from honest by any magnitude- or order-statistic test, so a coordinate-wise rule applied to a near-symmetric $\pm\mathbf{h}$ population has no reliable centre to estimate.

This laundering effect explains the empirical collapse of every coordinate-wise rule in Section IV and motivates direction-based detection: what cluster averaging cannot hide is the *sign* of the update. The proposition idealizes honest updates as a common $\mathbf{h}$; under non-IID heterogeneity real honest updates vary, so it predicts the boundary γ^* in the mean rather than exactly per cluster. We therefore read the four-dataset collapse as strong empirical validation *near* that boundary, not as a guarantee of collapse for arbitrary honest-update distributions.

E. CB-SAFE+: Temporal Group Testing over Cluster Sums

CB-SAFE+ turns the laundering signature into an identification mechanism, using three ingredients. (i) *Re-randomized*

clustering, one partition per round: the server draws a *single* fresh partition of the active clients into size- c clusters each round (pairwise secrets with all peers are established once at setup, so re-clustering adds no per-round KEM cost). Using *one* partition per round is a privacy requirement, not merely a convenience: it reveals exactly one size- c cluster sum per client (rank c), whereas placing a client in o groups *simultaneously* would reveal o overlapping sums of the same update and make the round's linear system solvable, defeating Theorem 1. The overlap that group testing needs is instead obtained *across* rounds (ingredient iii). (ii) *Loss-probe flags:* the server maintains a small root dataset ($|\mathcal{D}_0|=200$ samples held out from all clients, the standard trust-bootstrapping assumption [12], [13]), applies each cluster mean $\mathbf{S}_\ell$ to the current model θ^r , and records the change in root loss $\Delta_\ell^r = L(\theta^r + \mathbf{S}_\ell; \mathcal{D}_0) - L(\theta^r; \mathcal{D}_0)$. An absolute $\Delta_\ell > 0$ test over-flags, because an honest non-IID cluster mean can itself raise the loss slightly on a small balanced root set; we therefore flag *relative to the cleanest cluster of the round*,

$$g_\ell^r = \mathbb{I}\left[\Delta_\ell^r > \min_k \Delta_k^r + \delta\right], \quad (5)$$

with a small margin δ : a γ -amplified ascent direction spikes Δ_ℓ far above the cleanest cluster no matter whose data dominates the sum. Flags are computed from already-revealed cluster sums and server-local data, so they reveal no update content beyond those sums (Theorem 1). The probe is the product of two measured failures. Anchor-free direction flags are sign-ambiguous: the poisoned cluster sums form their own coherent cloud at $-\mathbf{h}$, and a Krum-based reference locks onto that cloud in a large fraction of rounds. Anchored *cosine* flags break the symmetry but lose specificity under non-IID data: an $m=1$ poisoned cluster mean is dominated by $-\gamma$ times one client's idiosyncratic direction, nearly orthogonal to the balanced anchor, so its sign test approaches a coin flip (at $f=0.2$ we measured cosine flags hitting clean clusters as often as dirty ones, and suspicion never separated). The loss probe is immune to this decorrelation because a γ -amplified ascent direction raises root loss regardless of whose data dominates the cluster sum. (iii) *Temporal group testing and adaptive exclusion:* across o consecutive rounds a client is re-clustered into o different groups, the across-round analog of o overlapping tests. A client accrues a suspicion mark in round r only if its cluster was flagged in *every* one of the last o rounds (a windowed combinatorial orthogonal matching pursuit (COMP) decode [10]); writing $G_i^r = \prod_{p=r-o+1}^r g_{\ell(i,p)}^p$ for that windowed conjunction ($o=1$ recovers plain per-round accumulation), after r rounds client i has accumulated

$$s_i^r = \sum_{p \leq r} G_i^p. \quad (6)$$

A malicious client accumulates suspicion far faster than an honest one—its flagged fraction plateaus near 0.73 in our runs—while an honest client is flagged only when randomly co-clustered with an attacker, with per-round probability

$$p_h = 1 - (1-f)^{c-1} < 1, \quad (7)$$

and only p_h^o across a full window, so overlap further suppresses honest false positives. After a warmup of W rounds the server

Algorithm 2: CB-SAFE+: Temporal Group Testing over Cluster Sums

Input: clients $[N]$, root $\mathcal{D}_0$, cluster size c , overlap o ,
warmup W , flag margin δ , rounds R
Output: global model θ , excluded set $\mathcal{E}$
 $s_i \leftarrow 0$, window $h_i \leftarrow () \forall i; \quad \mathcal{E} \leftarrow \emptyset$
for $r \leftarrow 1$ **to** R **do**
 redraw *one* random partition of $[N] \setminus \mathcal{E}$ into
 clusters of size c
 foreach cluster ℓ **do**
 $\mathbf{S}_\ell \leftarrow \text{CLUSTERSECUREAGG}(\ell, r) / |\text{alive}(\ell)|$;
 $\Delta_\ell \leftarrow L(\theta + \mathbf{S}_\ell; \mathcal{D}_0) - L(\theta; \mathcal{D}_0)$
 foreach cluster ℓ **do** $g_\ell \leftarrow \mathbb{I}[\Delta_\ell > \min_k \Delta_k + \delta]$
 // Eq. (5)
 foreach active client i , in its cluster ℓ **do**
 append g_ℓ to h_i and keep its last o entries
 if $|h_i|=o$ and $\min h_i=1$ **then** $s_i \leftarrow s_i + 1$
 // windowed COMP
 if $r > W$ **then** $\mathcal{E} \leftarrow \mathcal{E} \cup \text{GAPEXCLUDE}(\{s_i/r\})$
 // adaptive gap, Eq. (8)
 $\theta \leftarrow \theta + \text{ROBUSTAGG}(\{\mathbf{S}_\ell : g_\ell=0\})$
return $\theta, \mathcal{E}$

excludes clients by an *adaptive gap* rather than a fixed cut: it sorts the flagged fractions s_i^r/r , takes the largest gap between consecutive values, and excludes the high side when that gap exceeds a minimum separation, its midpoint σ^* sits above a floor, and the excluded set is a minority,

$$\text{exclude } i \iff r > W \text{ and } s_i^r/r > \sigma^*. \quad (8)$$

A fixed threshold τ is deliberately avoided: a γ -amplified attacker can plateau its flagged fraction just below any preset τ (we observed ~ 0.73 against $\tau=0.85$) and evade the cut, whereas the gap rule keys on the *separation* between the honest and malicious populations, which is present whenever an attack is. By Hoeffding's inequality those populations concentrate near p_h^o and 1 and separate exponentially, so a few rounds open a gap wide enough to cut, as the measured suspicion trajectories confirm (Fig. 7). The server thereby identifies individual attackers it has never observed individually: group testing [43], [44] whose pools are the privacy-preserving cluster sums and whose tests repeat, and overlap, over training rounds. At large populations ($N > N_0=50$) per-client data shrinks, so absolute loss deltas compress and the suspicion histogram densifies; the flag and the exclusion then switch to scale-invariant robust rules (upper median-plus-MAD outliers), which is what keeps CB-SAFE+ effective at $N=500$ (Section IV).

IV. EXPERIMENTAL SETUP

A. Implementation

CB-SAFE is implemented in Python on liboqs 0.15.0 (via liboqs-python) and PyTorch, with the KEM selected by a one-line configuration change among HQC-128/192/256 and ML-KEM-512/768/1024 (Kyber round-3 pa-

rameter sets are retained for comparison with older literature). Masks are ChaCha20 [61] keystreams; per-round seeds use HKDF-SHA256 [62]; self-mask seeds are shared with Shamir's scheme [60] over $\text{GF}(2^{127} - 1)$. *HQC provenance:* liboqs 0.15.0 ships the PQClean constant-time implementation of the Round-4 HQC specification [59] (2023-04-30), the version NIST evaluated and selected [2]; the finalized standard's parameters may differ slightly once published (a draft is expected as FIPS 207). Federated training is simulated in-process; every protocol byte count and crypto timing reported below is measured from real objects on the wire path of the protocol (public keys, ciphertexts, shares, masked vectors), not modeled. One training round of 30 clients takes ≈ 21 s on the RTX 2060; the full software and hardware configuration is given below.

B. Datasets, Models, and Protocol Configuration

1) *Task and data:* Primary task: CIFAR-10 partitioned across $N=30$ clients by a Dirichlet($\alpha=0.5$) label-skew split; a CNN with $d=291\,498$ parameters; one local epoch per round (SGD, lr 0.01, momentum 0.9, batch 64); $k=10$ clusters of $c=3$ unless stated. The split is sharply non-IID: clients hold 631 to 3298 samples with strongly skewed label distributions, the heterogeneity under which all robustness results are reported.

Generalization (Section V-F) adds FashionMNIST (same CNN), EMNIST-balanced (47 classes), and Edge-IIoTset (a 15-class tabular IoT intrusion-detection set with a multilayer perceptron), each Dirichlet-partitioned identically.

2) *Configurations:* Plain FedAvg (no cryptography); CB-SAFE/lattice (ML-KEM); CB-SAFE/code-based (HQC), at matched NIST levels.

3) *Attacks:* Label flipping ($y \rightarrow 9-y$), sign flipping (-5Δ), and a backdoor [17] (3×3 trigger patch, target class 0, 50% local poison rate) at malicious fractions $f \in \{0.1, 0.2, 0.3\}$, against aggregation rules mean, trimmed mean, median, Multi-Krum, and the CB-SAFE+ reputation defense (Section III-E; server root set of 200 samples held out from all clients).

4) *Metrics:* Test accuracy; backdoor attack success rate (ASR: fraction of triggered non-target test samples classified as the target); communication bytes per client (setup vs. per-round); crypto wall-time; dropout-recovery cost.

5) *Datasets and reproducibility:* The four benchmarks are CIFAR-10 [45] (50,000/10,000, 10 classes), FashionMNIST [46] (60,000/10,000, 10 classes), EMNIST-balanced [47] (112,800/18,800, 47 classes), and Edge-IIoTset [48] (tabular IoT/IIoT intrusion detection, the DNN-EdgeIIoT-dataset.csv release of 2,219,201 flows over 15 classes, class-stratified to at most 120,000 rows), each Dirichlet($\alpha=0.5$) [49] partitioned across $N=30$ clients. Unless stated: overlap degree $o \in \{1, 4\}$, Shamir threshold $t=\lfloor c/2 \rfloor + 1=2$, server root $|\mathcal{D}_0|=200$ held out from all clients, and adaptive-gap exclusion (flag margin $\delta=0.25$, minimum suspicion gap 0.15, floor 0.25) after a warmup of $W=5$ rounds; for $N>50$ the flag and exclusion switch to robust median-plus-MAD thresholds (1.0 and 2.5 MAD). KEMs span HQC-128/192/256 and ML-KEM-512/768/1024

TABLE I
MEASURED PER-CLIENT OVERHEAD ($N=30$, $c=3$, $d=291\,498$). SETUP IS ONE-TIME; PER-ROUND TRAFFIC IS KEM-INDEPENDENT.

KEM	Setup (KiB)	Setup wall (s)	Round (KiB)	Mask (ms)
ML-KEM-512	3.8	0.02	2 277	25
HQC-128	15.2	2.0	2 277	26
ML-KEM-768	5.6	0.02	2 277	27
HQC-192	30.8	5.7	2 277	25
ML-KEM-1024	7.7	0.02	2 277	25
HQC-256	49.4	10.6	2 277	26

at matched NIST levels; masks are ChaCha20 keystreams with HKDF-SHA256 per-round seeds. Runs use Python 3.12, PyTorch 2.5.0 (CUDA 12.4), and liboqs-python 0.15.0 on NVIDIA RTX 2060 (6 GB) and RTX 5080 (16 GB) GPUs; all results are averaged over three seeds, with significance by paired t -tests (Holm-corrected).

V. RESULTS AND DISCUSSION

A. Communication and Computation Overhead

Table I reports measured per-client traffic and crypto time. Per-round traffic is identical across all six KEMs (2 277 KiB per client, dominated by the $8d$ -byte masked update plus 102 B of Shamir material) because Definition 1 keeps KEM objects out of the per-round path entirely. The KEM appears only in setup: at NIST level 1, HQC costs 15.2 KiB per client against ML-KEM’s 3.8 KiB ($4.0\times$; $6.4\times$ at level 5), and 2.0 s of one-time compute for all 30 clients against 0.02 s. Amortized over 40 training rounds (~ 89 MiB of per-client update traffic), the code-based premium is below 0.03% of total communication (Table I). A round with 10% dropouts adds only seed-reveal messages (32 B per survivor-dropout pair) and kept server unmasking below 0.28 s in all configurations.

1) *Dropout tolerance*: With $c=3$ and $t=\lfloor c/2 \rfloor + 1 = 2$, a cluster survives one dropout but not two: at two losses the threshold cannot be met and the whole cluster is discarded, taking its surviving honest update with it. Under an i.i.d. dropout rate p the expected fraction of clusters lost is

$$\Pr[2 \text{ or } 3 \text{ of } c=3 \text{ drop}] = 3p^2(1-p) + p^3, \quad (9)$$

so 2.8% of clusters at $p=0.10$, 10.4% at $p=0.20$ and 21.6% at $p=0.30$; our 10%-dropout runs discarded one of ten clusters, consistent with that. Larger c both widens the anonymity set and raises the dropout budget, while lowering the probability a cluster sum stays clean — so dropout tolerance belongs on the same privacy-robustness dial as $(1-f)^c$, not beside it. The practicality question that motivated this work has a quantitative answer: *cryptographic diversity in FL secure aggregation is essentially free at the protocol level once key establishment is amortized*: the trade-off is a one-time setup constant, not a per-round tax.

B. Scalability in the Client Population

Secure-aggregation cost is set by how many pairwise partners each client must maintain. All-pairs masking [1] gives

every client $N-1$ partners, so per-client setup traffic and per-round mask derivation grow as $O(N)$. CB-SAFE masks only *within* clusters of size c , capping partners at $c-1$.

The two variants have different setup costs, and we state them separately. With *fixed* clusters, a client ever masks with the same $c-1$ partners, so both quantities are *constant in* N : extrapolating the measured HQC-128 and ML-KEM-512 primitives (Table I) by partner count, a client’s one-time setup is 15.2 KiB (HQC) or 3.8 KiB (ML-KEM) at any population, versus 7.4 MiB for all-pairs masking at $N=1000$ — a $500\times$ reduction that widens linearly with N .

CB-SAFE+ does not inherit that saving. Re-randomizing the partition every round means any peer may become a cluster mate, so a client must hold a pairwise secret with all $N-1$ peers. That establishment is one-time rather than per-round, but it is $O(N)$: the same 7.4 MiB at $N=1000$, and 3.7 MiB at the $N=500$ of Table II. What re-randomization buys is that this cost is paid once and the *per-round* traffic stays $O(c)$ — mask derivation over $c-1$ partners — so the saving is in recurring bandwidth, not in setup. Since every robustness result in Section IV comes from CB-SAFE+, the constant-in- N setup figure should be read as applying to the fixed-cluster configuration only. Removing this gap — per-round encapsulation with only the new mates, which reintroduces per-round KEM traffic, or a hash-based key tree that derives cluster keys without all-pairs establishment — is the obvious next step and we do not claim it here.

Because the privacy law $\Pr[S_j \text{ clean}] = (1-f)^c$ and the laundering boundary (Prop. 1) are stated *per cluster*, they are independent of N . CB-SAFE therefore targets the cross-device regime where recurring all-pairs mask derivation is infeasible.

1) *Scaling the client population*: Cost is only half the scaling question; the other is whether robustness survives a $16\times$ larger client population. We ran every rule that admits a configuration at $N=500$ under sign-flip ($f=0.2$) for 50 rounds (Table II, Fig. 3). FedGT is necessarily absent here: its parity-check matrices and prevalence-estimation tables are hardcoded for $n \leq 31$ [20], so it has no configuration at this population and cannot be run without hand-designing new ones—a concrete scalability ceiling in the method, not a tuning choice. At this scale each client holds only ~ 100 samples and attacker exclusion consumes the first ~ 15 – 20 rounds, so a short 30-round budget truncates every method mid-recovery; extending to 50 rounds lets recovery complete and collapses the between-seed spread (from ± 10 to ± 2 , Fig. 3). At the converged horizon CB-SAFE+ reaches 65.7% (last-five-round mean over three seeds), the coordinate-wise rules remain laundered near chance, and FLTrust’s trust weighting, which recovers fastest early, plateaus ~ 4 points lower (61.3%) because soft down-weighting never fully removes the laundered mass. CB-SAFE+ reaches that accuracy while excluding only 11 honest clients of 400 (2.75%). Among the methods that admit a configuration at this scale, CB-SAFE+ is the only one that pairs top-tier robustness with near-zero honest exclusion and post-quantum security.

TABLE II

SCALING WITH THE CLIENT POPULATION. TEST ACCURACY (%) AT $N=100$ (30 ROUNDS) AND $N=500$ (50 ROUNDS) UNDER SIGN-FLIP $f=0.2$ ON FASHIONMNIST (DIRICHLET $\alpha=0.5$); PER-SEED VALUES ARE THE MEAN OF THE FINAL FIVE ROUNDS, OVER THREE SEEDS. THE DETECTION BLOCK REPORTS, AT $N=500$, MALICIOUS CLIENTS CAUGHT OF 100, HONEST CLIENTS WRONGLY EXCLUDED (FP) OF 400, AND THE DERIVED FALSE-ALARM (P_{FA}) AND MISSED-DETECTION (P_{MD}) RATES. BEST VALUE PER COLUMN IN BOLD. AT A CONVERGED HORIZON THE TWO GROUP-TESTING METHODS TIE AT THE TOP; COORDINATE-WISE RULES COLLAPSE; ONLY CB-SAFE+ PAIRS TOP ACCURACY WITH NEAR-ZERO FALSE EXCLUSION. ROUNDS SCALE WITH N BECAUSE ATTACKER EXCLUSION CONSUMES A FIXED NUMBER OF EARLY ROUNDS REGARDLESS OF POPULATION.

Method	$N=100$ (30 rd)				$N=500$ (50 rd)				Detection ($N=500$)				
	s0	s1	s2	mean $\pm$ sd	s0	s1	s2	mean $\pm$ sd	Caught	FP $\downarrow$	$P_{FA}\downarrow$	$P_{MD}\downarrow$	Id.
CB-SAFE+ (ours)	76.1	75.2	73.4	74.9$\pm$1.4	69.8	69.0	67.0	68.6$\pm$1.5	100/100	12	0.029	0.003	✓
FLTrust [12]	68.9	65.5	64.2	66.2 $\pm$ 2.4	63.0	58.6	62.3	61.3 $\pm$ 2.4	—	—	—	—	×
Median	71.8	63.5	68.5	67.9 $\pm$ 4.2	29.8	29.1	16.5	25.1 $\pm$ 7.5	—	—	—	—	×
Geo-median [22]	73.4	65.4	68.8	69.2 $\pm$ 4.0	38.2	30.2	18.5	28.9 $\pm$ 9.9	—	—	—	—	×
Multi-Krum	10.0	10.0	40.4	20.1 $\pm$ 17.6	10.0	9.9	10.0	10.0 $\pm$ 0.1	—	—	—	—	×
Bulyan [21]	10.0	10.0	44.2	21.4 $\pm$ 19.8	10.0	12.3	10.0	10.8 $\pm$ 1.3	—	—	—	—	×
Trimmed mean	10.0	10.0	10.0	10.0 $\pm$ 0.0	10.0	8.4	10.0	9.5 $\pm$ 0.9	—	—	—	—	×
Mean	10.0	10.0	10.0	10.0 $\pm$ 0.0	10.0	10.0	10.0	10.0 $\pm$ 0.0	—	—	—	—	×

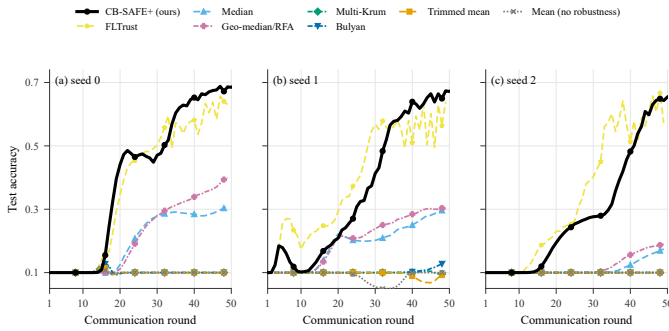


Fig. 3. Test accuracy vs round at $N=500$ (FashionMNIST, sign-flip $f=0.2$), one panel per seed; eight rules (FedGT excluded, see text).

C. Utility and Cryptographic Equivalence

Plain FedAvg reaches 59.0% test accuracy (mean of the final five of 40 rounds; 59.6% at round 40) on the non-IID split. This equivalence check is a single 40-round run rather than the 50-round, three-seed protocol of the robustness experiments, since its purpose is bit-level agreement between the plain and secure sums rather than a converged accuracy; the corresponding converged figure is the 62.4% of Table III. In every round, the same client updates were pushed through the full cryptographic pipeline twice (once under HQC-128, once under ML-KEM-768), and every per-cluster secure sum was compared coordinate-wise against the plain sum. The maximum deviation across all 40 rounds and both KEMs was 2.28×10^{-5} , which equals the worst-case fixed-point rounding bound for a 3-element sum ($3 \cdot 2^{-17} = 2.29 \times 10^{-5}$): the masking arithmetic itself is exact, so CB-SAFE's accuracy curve is identical to plain FedAvg by construction, not approximately. Both dropout modes were exercised: in round 10, two of three dropped clients landed in the same cluster, driving it below its $t=2$ threshold: the protocol excluded that cluster and recovered the remaining nine exactly; in round 20, three dropouts in three distinct clusters were all recovered by seed-reveal plus Shamir reconstruction. Measured in-run, setup cost 2.0 s (HQC-128) vs. 0.02 s (ML-KEM-512, matched NIST

level 1) for all 30 clients, and steady-state rounds took ~ 30 ms of client-side masking and ~ 0.29 s of server-side unmasking, negligible against the ~ 21 s of local training per round.

D. Baseline Configuration and Validity

Robust rules are applied across the $k=\lceil N/c \rceil$ revealed cluster sums, not across individual clients, so their own preconditions must be restated in terms of *contaminated cluster sums* rather than malicious clients. With $N=30$, $c=3$ we have $k=10$ inputs, and the expected number of contaminated sums is

$$\mathbb{E}[\text{contaminated sums}] = k(1 - (1 - f)^c), \quad (10)$$

giving 2.7 at $f=0.1$, 4.9 at $f=0.2$ and 6.6 at $f=0.3$. We configure both selection rules with $b = \lceil k(1 - (1 - f)^c) \rceil$. Their published preconditions are

$$\text{Multi-Krum: } k > 2b + 2, \quad \text{Bulyan: } k \geq 4b + 3; \quad (11)$$

at $k=10$ these hold only for $b \leq 3$ and $b \leq 1$ respectively by (11). Bulyan is therefore already outside its guarantee at $f=0.1$ and Multi-Krum from $f=0.2$ on. Their degradation at high f is the expected consequence of that, not evidence against them, and we say so rather than present it as a finding; the laundering claim rests on the coordinate-wise rules, which have no such precondition.

FLTrust is given the same $|\mathcal{D}_0|=200$ root set as CB-SAFE+, so the two consume identical server-side data. An earlier revision of these results used a server-update normalization that suppressed FLTrust's trust weights; correcting it raised FLTrust substantially (for example, on Edge-IIoTset under sign-flip from 50.4/43.3/39.9 to 63.1/62.6/62.5), and all FLTrust numbers reported here are from the corrected implementation. FedGT is our reimplement of its published BCJR decoder rather than an accuracy-thresholded stand-in, run at the $N=30$, group-size-3 configuration its paper covers.

The no-attack column (Table III) exists so these can be told apart: a rule scoring below the undefended mean at $f=0$ is paying for its own aggregation, before any attacker acts. On CIFAR-10 the undefended mean reaches 62.4%; FLTrust

TABLE III

NO-ATTACK REFERENCE ACCURACY (%) AT $f=0$ ACROSS ALL FOUR BENCHMARKS (MEAN $\pm$ STD OVER 3 SEEDS, 50 ROUNDS). EVERY RULE IS APPLIED TO BENIGN UPDATES ONLY, SO A VALUE BELOW THE UNDEFENDED MEAN IS THE COST OF THE AGGREGATION RULE ITSELF RATHER THAN OF ANY ATTACK. READ THE ROBUSTNESS TABLES AGAINST THIS COLUMN. FEDGT IS RUN THROUGH THE SAME HARNESS AS THE OTHER RULES HERE: WITHOUT AN ATTACK ITS GROUP-TESTING DECODER IS INACTIVE.

Method	CIFAR-10	FashionMNIST	EMNIST	Edge-II
FedAvg (mean) [26]	62.4 $\pm$ 0.1	87.9 $\pm$ 0.4	86.9 $\pm$ 0.2	65.5 $\pm$ 0.1
Trimmed mean [16]	61.6 $\pm$ 0.2	87.8 $\pm$ 0.4	86.8 $\pm$ 0.1	65.1 $\pm$ 0.1
Median [16]	61.4 $\pm$ 0.4	87.8 $\pm$ 0.3	86.7 $\pm$ 0.1	64.5 $\pm$ 0.1
Multi-Krum [15]	59.5 $\pm$ 0.2	87.6 $\pm$ 0.4	85.6 $\pm$ 0.3	63.1 $\pm$ 0.1
Bulyan [21]	59.2 $\pm$ 0.9	87.4 $\pm$ 0.4	85.7 $\pm$ 0.2	63.7 $\pm$ 0.1
Geo-median / RFA [22]	62.0 $\pm$ 0.1	87.9 $\pm$ 0.4	86.9 $\pm$ 0.2	65.1 $\pm$ 0.1
FLTrust [12]	51.9 $\pm$ 2.0	83.5 $\pm$ 0.9	84.6 $\pm$ 0.4	63.7 $\pm$ 0.1
FedGT [20]	61.9 $\pm$ 0.4	87.9 $\pm$ 0.5	86.9 $\pm$ 0.2	65.9 $\pm$ 0.1
CB-SAFE+ (ours)	62.1 $\pm$ 0.4	88.0 $\pm$ 0.4	86.9 $\pm$ 0.2	65.3 $\pm$ 0.1

costs 10.5 points against it (51.9%), Bulyan 3.2 and Multi-Krum 2.9, while every remaining rule—CB-SAFE+ included, at 62.1%—is within 0.9 points. Robustness numbers should be read against that column, not against 100%.

E. Robustness Under Attack

1) *Cluster contamination*: Across all runs, the realized fraction of clean cluster sums tracked $(1-f)^c$ closely: at $c=3$, observed 0.70/0.50/0.40 versus predicted 0.73/0.51/0.34 for $f=0.1/0.2/0.3$.

Sign-flip: laundering collapses coordinate-wise rules exactly at the predicted boundary (Table V, Fig. 5). At $f=0.1$ (≈ 3 dirty clusters, within trim capacity) the static rules work: trimmed mean 51.7%, median 55.5%, Multi-Krum 60.5%, versus 20.0% for the undefended mean and $\sim 60\%$ clean baseline. At $f=0.2$ (≈ 5 dirty clusters) every coordinate-wise rule is pinned at exactly 10.0% (random guessing): with the laundered $\pm h$ population straddling zero, no per-coordinate statistic recovers the honest direction (Proposition 1), while Multi-Krum, which selects whole vectors rather than per-coordinate statistics, still reaches 45.3% (21.4% at $f=0.3$). Robust rules that rely on magnitude order statistics are structurally weakened by the very mechanism that provides privacy; vector-selection rules retain power.

2) *Attack amplitude*: Since $\gamma^*=5$ is the exact laundering point $\gamma^*=2c/m-1$, one might ask whether the collapse is an artifact of that singular value. Sweeping $\gamma \in \{2, 3, 5, 8, 15\}$ at $f=0.2$ (Fig. 4) shows it is not: median and trimmed mean collapse to 10% at every $\gamma \geq \gamma^*$ and only partially degrade below it, and Multi-Krum—robust until $\gamma=8$ —itself collapses at $\gamma=15$. CB-SAFE+ holds $\sim 50\text{--}57\%$ throughout, reaching 57.5% at $\gamma=5$ (Table V). Bulyan matches it here, its trim capacity not exceeded at $f=0.2$; that parity breaks at $f=0.3$ (Table V), where identifying attackers rather than merely trimming them decides the outcome.

3) *The full baseline panel*: Across Fig. 5, Fig. 6 and Table V, averaged over three seeds, the eight rules separate into three regimes at $f=0.3$: the coordinate-wise rules (mean, trimmed mean, median) are laundered to chance ($\approx 10\%$) and

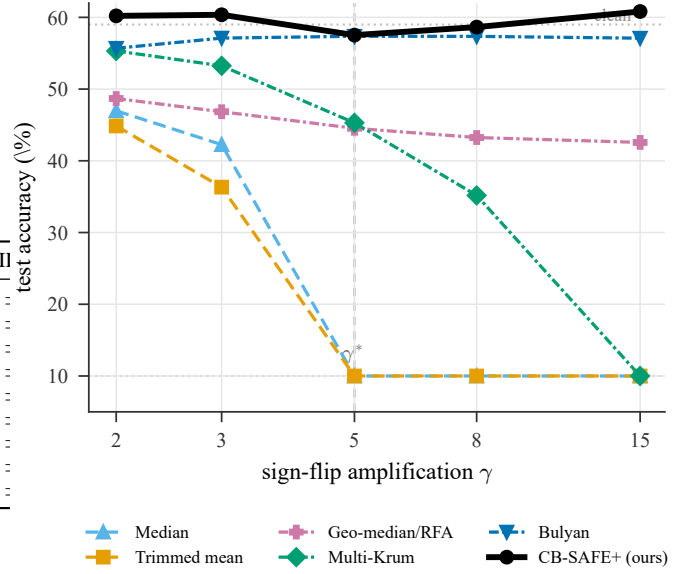


Fig. 4. Sign-flip amplification sweep (CIFAR-10, $f=0.2$, 3 seeds): test accuracy vs γ . Coordinate-wise rules collapse for all $\gamma \geq \gamma^*=5$; dashed lines mark chance and the clean baseline.

TABLE IV

ATTACKER IDENTIFICATION, CIFAR-10 SIGN-FLIP ($N=30$, 3 SEEDS): ATTACKERS CAUGHT ($\uparrow$) AND HONEST FALSE POSITIVES ($\downarrow$). FEDGT IS ITS REAL BCJR DECODER [20]. BEST IN BOLD.

Method	$f=0.1$		$f=0.2$		$f=0.3$	
	caught $\uparrow$	FP $\downarrow$	caught $\uparrow$	FP $\downarrow$	caught $\uparrow$	FP $\downarrow$
FedGT [20]	2.7/3	13.0	5.3/6	17.7	7.7/9	11.0
CB-SAFE+ (ov1)	3/3	0.7	4/6	0.7	6.3/9	1.3
CB-SAFE+ hybrid	3/3	0.3	6/6	0.3	9/9	0.0

the robust geometric median RFA [22] degrades to $\sim 20\%$, confirming that location- and magnitude-based aggregation fails regardless of sophistication; the vector-selection family degrades but falls (Multi-Krum 21%, Bulyan [21] 35%); and only CB-SAFE+ holds near the clean baseline at 57.4%, whereas FedGT's actual BCJR decoder [20], run per round, degrades to 34% on CIFAR-10 (and collapses to near-chance on FashionMNIST and EMNIST) at this contamination by over-excluding honest clients (Table IV). That RFA collapses while Bulyan merely degrades sharpens Proposition 1: laundering specifically defeats rules that trust the *aggregate* direction or magnitude, precisely what cluster averaging preserves for the attacker, whereas whole-vector selection resists longer.

4) *CB-SAFE+ beyond the static breakdown*: In Table V, with loss-probe flags and temporal suspicion, the defense identifies all 3 of 3 attackers at $f=0.1$ (60.5%, at the clean ceiling) and all 9 sign-flip attackers with *zero* honest false positives at $f=0.3$ (three-seed means in Table IV), recovering to 57.4% accuracy where every static coordinate-wise rule sat at 10% and Multi-Krum at 21.4%—exceeding even the 39–41% the median achieves *without any privacy* ($c=1$), i.e., the defense refunds the privacy dial's cost in rounds rather than anonymity. At $f=0.2$ it holds 57.5% while Multi-Krum reaches only 45.3%, so the defense's advantage over vector-

selection rules grows with attack severity. Under label flipping (a weak attack in this regime: all rules land within 44–52%) the probe flags only the worst clusters and excludes conservatively (zero false positives at $f=0.2$), matching the best static rule.

5) *Backdoor attacks*: The trigger attack leaves main-task accuracy intact for every rule (50–55%) while ASR stays at 86–97% across mean, trimmed mean, Multi-Krum, and CB-SAFE+: backdoored cluster sums *reduce* clean root loss and align with the honest direction, so they are invisible to loss- and direction-based tests alike. Among the rules compared here, the partial exception at $f=0.1$ is the coordinate-wise median, which suppresses ASR to 67% on CIFAR-10 (and to 42% on FashionMNIST): order statistics can filter the trigger direction’s coordinates when contamination is sparse. We therefore claim CB-SAFE+ for *untargeted* model poisoning only; targeted trigger attacks under secure aggregation remain open, consistent with their difficulty even without privacy constraints, and we do not position CB-SAFE+ against defenses built for them.

F. Generalization Across Datasets and Modalities

To test whether the laundering effect and CB-SAFE+’s recovery are artifacts of one dataset, we repeat the sign-flip evaluation on three further benchmarks, each with three seeds: FashionMNIST (a second image task on the same CNN), EMNIST-balanced (47 classes, a harder label space), and Edge-IIoTset (tabular IoT/IIoT intrusion detection with a multilayer perceptron, a different modality in the security domain of the closest prior work [7]). The pattern is identical everywhere (Table V, Fig. 5): every coordinate-wise rule collapses to chance at $f \geq 0.2$ (10.0% on the 10-class image sets, 7.3% on 15-class Edge-IIoTset), Multi-Krum degrades gracefully then falls at $f=0.3$, and CB-SAFE+ tracks the clean baseline. The round-by-round view (Fig. 5) shows this is not an endpoint artifact: the static rules decay progressively while CB-SAFE+ dips during warmup and recovers as exclusions fire. At $f=0.3$ CB-SAFE+ retains $\sim 95\%$, $\sim 99\%$, and $\sim 99\%$ of the no-attack accuracy on CIFAR-10, FashionMNIST, and Edge-IIoTset respectively, versus 12–18% for the worst static rule. Pooling all 36 matched (dataset, f , seed) cells, CB-SAFE+ beats *every* baseline under a paired t -test with Holm correction across the eight comparisons: the mean by 56.8 points ($p < 10^{-15}$), trimmed mean by 45.5 and median by 43.5 (both $p < 10^{-9}$), geometric median by 20.9 ($p < 10^{-4}$), Multi-Krum by 18.1 ($p < 10^{-4}$), FedGT’s actual BCJR decoder by 18.3 ($p < 10^{-4}$), Bulyan by 12.4 ($p = 0.007$), and FLTrust by 5.0 ($p < 10^{-9}$).

Two qualifications on that test. It pools heterogeneous configurations, so it establishes a population-level ordering, not a per-cell one: at individual cells the ranking does change hands—FedGT ties CB-SAFE+ on FashionMNIST at $f=0.1$ and leads it on Edge-IIoTset at $f=0.2$ (65.6 vs 65.2), and Bulyan leads at Edge-IIoTset $f=0.1$. Per-cell values are in Table V and should be read directly. Second, the cells are not independent (three seeds share a dataset and fraction), so the p -values are indicative rather than exact; the weakest comparison, Bulyan, is the one to weigh, and it is also the rule

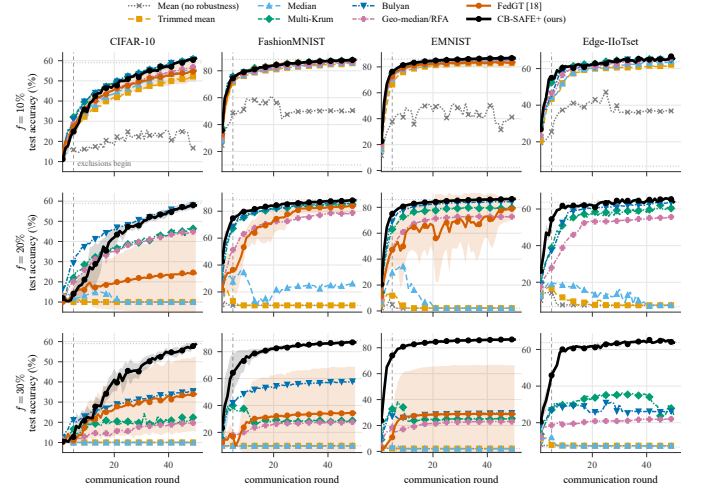


Fig. 5. Training dynamics under sign-flip: test accuracy vs round, eight rules across four datasets (columns) $\times$ malicious fraction f (rows). Mean over 3 seeds; ± 1 SD bands for CB-SAFE+ and FedGT (real BCJR [20]). Dashed line: warmup $W=5$.

operating furthest outside its own precondition (Section V-D). The Edge-IIoTset result is the sharpest: at $f=0.3$ CB-SAFE+ holds 64.5% against a $\sim 65\%$ clean baseline while mean, trimmed mean, and median all sit at 7.4%. FLTrust is the one baseline that also withstands laundering on this dataset, trailing CB-SAFE+ by 2.0 points there (62.5% vs 64.5%); that is the smallest margin we report, which is why it is tested explicitly above.

G. Label-Flipping Attack

Label flipping is a far milder attack than sign-flip, and it doubles as a control. Table VI shows that *no* coordinate-wise rule collapses: the undefended mean retains 53–64% at $f=0.3$, versus 10% under sign-flip. That contrast isolates the laundering mechanism (Proposition 1) as the cause of the sign-flip failures, rather than any generic fragility of the setup. CB-SAFE+ leads on the image benchmarks—on FashionMNIST it holds 87% at $f=0.3$ where the mean falls to 59%—while on Edge-IIoTset all nine rules fall within 4.0 points of one another, so the ordering there is a wash and trimmed mean edges ahead at $f=0.2$ (66.3% vs 64.3%). We read that as the control behaving as intended: with no laundering to exploit, robust aggregation has little left to recover, so the separation that matters appears only under sign-flip. FedGT’s actual BCJR decoder survives this mild attack—unlike its sign-flip collapse—but trails CB-SAFE+ on CIFAR-10 (~ 50 –56% vs ~ 56 –61%) and is noisier between seeds, so even where its accuracy signal is informative it is the less stable identifier.

H. Adaptive Attackers

1) *Amplitude-adaptive: choosing γ to evade the loss probe*: The direction flag fires on a loss margin δ , so an attacker that knows the defense should tune its amplitude γ rather than maximize it: too large and every cluster it touches is flagged, too small and the poisoning does little. We therefore sweep $\gamma \in \{2, 3, 5, 8, 15\}$ at $f=0.2$ on CIFAR-10 (three seeds, 50

TABLE V

TEST ACCURACY (%) UNDER THE SIGN-FLIP (LAUNDERING) ATTACK ACROSS FOUR DATASETS AND MALICIOUS FRACTIONS f (MEAN $\pm$ STD OVER 3 SEEDS, 50 ROUNDS). HIGHER IS BETTER; BEST PER COLUMN IN BOLD. CB-SAFE+ VARIANTS ARE ABLATED IN TABLE VIII.

Method	CIFAR-10			FashionMNIST			EMNIST			Edge-IIoTset		
	$f=.1$	$f=.2$	$f=.3$	$f=.1$	$f=.2$	$f=.3$	$f=.1$	$f=.2$	$f=.3$	$f=.1$	$f=.2$	$f=.3$
FedAvg (mean) [26]	20.0 $\pm$ 8.3	10.0 $\pm$ 0.0	10.0 $\pm$ 0.0	49.7 $\pm$ 29.2	10.0 $\pm$ 0.0	10.0 $\pm$ 0.0	39.7 $\pm$ 26.7	2.1 $\pm$ 0.0	2.1 $\pm$ 0.0	36.8 $\pm$ 21.7	7.4 $\pm$ 0.2	7.4 $\pm$ 0.2
Trimmed mean [16]	51.7 $\pm$ 1.0	10.0 $\pm$ 0.0	10.0 $\pm$ 0.0	85.5 $\pm$ 1.0	10.0 $\pm$ 0.0	10.0 $\pm$ 0.0	83.1 $\pm$ 0.3	2.1 $\pm$ 0.0	2.1 $\pm$ 0.0	61.7 $\pm$ 2.6	7.4 $\pm$ 0.2	7.4 $\pm$ 0.2
Median [16]	55.5 $\pm$ 1.5	10.0 $\pm$ 0.0	10.0 $\pm$ 0.0	86.0 $\pm$ 0.7	25.4 $\pm$ 21.8	10.0 $\pm$ 0.0	84.6 $\pm$ 0.0	2.1 $\pm$ 0.0	2.1 $\pm$ 0.0	63.7 $\pm$ 0.6	7.6 $\pm$ 0.2	7.4 $\pm$ 0.2
Multi-Krum [15]	60.5 $\pm$ 0.6	45.3 $\pm$ 2.0	21.4 $\pm$ 11.6	87.6 $\pm$ 0.4	85.0 $\pm$ 1.2	28.1 $\pm$ 25.5	86.0 $\pm$ 0.2	79.2 $\pm$ 0.8	25.2 $\pm$ 32.7	65.2 $\pm$ 0.2	60.5 $\pm$ 1.3	25.9 $\pm$ 23.2
Bulyan [21]	60.3 $\pm$ 0.5	57.4 $\pm$ 0.6	35.4 $\pm$ 19.4	87.3 $\pm$ 0.3	86.0 $\pm$ 1.0	57.6 $\pm$ 33.7	85.8 $\pm$ 0.3	84.4 $\pm$ 0.3	29.5 $\pm$ 38.7	65.5 $\pm$ 0.4	63.3 $\pm$ 0.9	26.0 $\pm$ 26.2
Geo-median / RFA [22]	56.5 $\pm$ 0.7	44.5 $\pm$ 1.3	19.5 $\pm$ 13.5	86.3 $\pm$ 0.7	78.6 $\pm$ 2.1	27.5 $\pm$ 24.8	84.9 $\pm$ 0.2	72.8 $\pm$ 1.4	23.0 $\pm$ 29.5	65.1 $\pm$ 0.4	55.4 $\pm$ 9.2	21.9 $\pm$ 20.4
FLTrust [12]	50.6 $\pm$ 0.9	49.7 $\pm$ 0.3	46.9 $\pm$ 1.4	83.2 $\pm$ 1.3	84.0 $\pm$ 0.4	83.0 $\pm$ 1.5	82.9 $\pm$ 1.1	80.5 $\pm$ 1.7	78.5 $\pm$ 3.6	63.1 $\pm$ 0.5	62.6 $\pm$ 0.5	62.5 $\pm$ 0.6
FedGT [20]	54.4 $\pm$ 5.2	24.2 $\pm$ 20.1	33.7 $\pm$ 18.3	87.9 $\pm$ 0.3	83.7 $\pm$ 4.7	34.3 $\pm$ 34.4	83.4 $\pm$ 3.9	78.6 $\pm$ 9.1	28.8 $\pm$ 37.8	65.3 $\pm$ 2.7	65.6 $\pm$ 1.1	27.0 $\pm$ 27.9
CB-SAFE+ (ours)	60.5 $\pm$ 0.5	57.5 $\pm$ 1.6	57.4 $\pm$ 1.8	87.9 $\pm$ 0.3	88.0 $\pm$ 0.4	86.9 $\pm$ 0.8	86.7 $\pm$ 0.2	86.4 $\pm$ 0.1	86.4 $\pm$ 0.2	65.4 $\pm$ 0.5	65.2 $\pm$ 0.2	64.5 $\pm$ 0.8

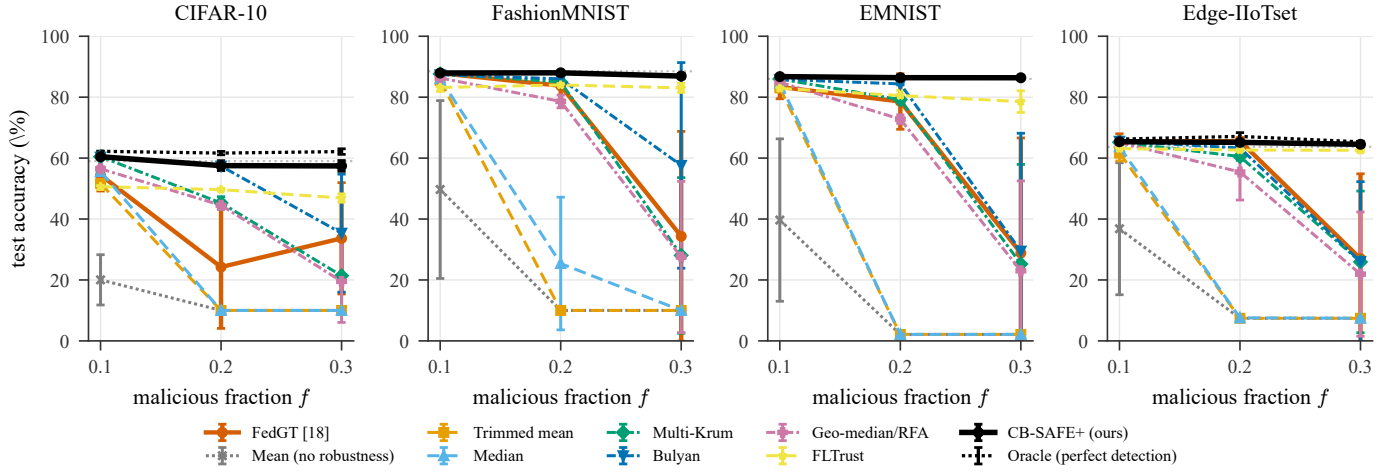


Fig. 6. Final test accuracy vs. malicious fraction f under sign-flip (mean over 3 seeds, 50 rounds; error bars ± 1 SD), one panel per dataset. The coordinate-wise rules (mean, trimmed mean, median) and the geometric median collapse to chance by $f=0.2$; Multi-Krum and Bulyan degrade then fall at $f=0.3$; only CB-SAFE+ tracks the clean baseline (grey dotted) across all four datasets, staying within a few points of the oracle (black dotted: perfect detection, all malicious clients excluded from round 1). This is the endpoint summary of the round-by-round view in Fig. 5.

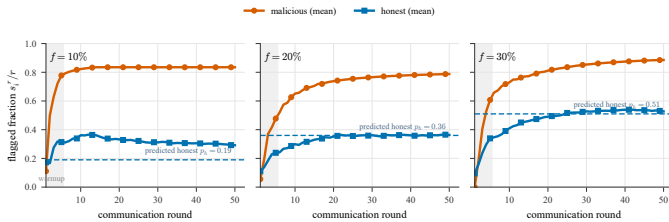


Fig. 7. Temporal suspicion (CB-SAFE+, CIFAR-10): mean flagged fraction s_i^T/r for malicious vs honest clients, per fraction f (3 seeds). Dashed: predicted honest rate $p_h = 1 - (1 - f)^{c-1}$; warmup shaded.

rounds) and report, for each rule, the accuracy an attacker could force by picking its best γ :

Rule	$\gamma=2$	$\gamma=3$	$\gamma=5$	$\gamma=8$	$\gamma=15$
Median	47.0	42.3	10.0	10.0	10.0
Multi-Krum	55.3	53.2	45.3	35.2	10.0
Bulyan	55.7	57.1	57.4	57.3	57.1
CB-SAFE+	60.2	60.4	57.5	58.6	60.8

The worst case per rule is in bold. For the coordinate-wise median and Multi-Krum an amplitude-adaptive attacker reaches chance (10.0%); for CB-SAFE+ the worst attainable value is 57.5%, at $\gamma=5$ — which is exactly γ^* from (4) at

$c=3$, $m=1$, and the amplitude used throughout the rest of this paper. The headline configuration is therefore already the attacker's best choice against CB-SAFE+, and the basin is shallow: no γ in the sweep moves it more than 3.3 points. Small γ does not evade the probe, because the suspicion score accumulates over rounds rather than requiring any single round to exceed a margin. This is amplitude adaptivity only; a fully optimized attacker in the style of [23], [24], [39], solving for the update that maximizes damage subject to staying within the flag margin, is not evaluated here and remains the strongest open threat to this design.

2) *Duty-cycled: poisoning intermittently*: Suspicion-based exclusion invites an obvious evasion: poison only a fraction δ of rounds, keeping most of the attack while holding the flagged fraction low enough to blend into the honest side of the suspicion gap. We test this directly (Table VII), and it fails. Because the partition is re-randomized every round, a resting attacker is still flagged whenever it co-clusters with an *active* one, so its accumulated suspicion runs ahead of its nominal duty: even at a high duty $\delta=0.84$, CB-SAFE+ still excludes all six attackers in every seed. Across $\delta \in [0.5, 1.0]$ accuracy never drops below 57% (clean baseline 59%), where coordinate-wise rules sit at 10%. At low duty the attacker

TABLE VI

TEST ACCURACY (%) UNDER THE LABEL-FLIP ATTACK ACROSS FOUR DATASETS AND MALICIOUS FRACTIONS f (MEAN $\pm$ STD OVER 3 SEEDS, 50 ROUNDS). LABEL FLIPPING IS A MILD ATTACK: UNLIKE SIGN-FLIP (TABLE V), COORDINATE-WISE RULES DO *not* COLLAPSE, WHICH ISOLATES LAUNDERING AS THE MECHANISM BEHIND THE SIGN-FLIP FAILURES. HIGHER IS BETTER; BEST PER COLUMN IN BOLD.

Method	CIFAR-10			FashionMNIST			EMNIST			Edge-IIoTset		
	$f=.1$	$f=.2$	$f=.3$	$f=.1$	$f=.2$	$f=.3$	$f=.1$	$f=.2$	$f=.3$	$f=.1$	$f=.2$	$f=.3$
FedAvg (mean) [26]	60.4 $\pm$ 0.6	57.1 $\pm$ 1.0	53.1 $\pm$ 1.5	87.2 $\pm$ 0.5	80.0 $\pm$ 0.4	58.9 $\pm$ 5.2	85.6 $\pm$ 0.0	82.8 $\pm$ 0.1	64.1 $\pm$ 2.0	64.7 $\pm$ 0.3	65.5 $\pm$ 1.0	64.1 $\pm$ 0.7
Trimmed mean [16]	60.1 $\pm$ 0.3	57.2 $\pm$ 0.2	54.2 $\pm$ 1.1	87.3 $\pm$ 0.4	82.8 $\pm$ 0.3	72.1 $\pm$ 3.0	86.1 $\pm$ 0.2	83.9 $\pm$ 0.1	79.1 $\pm$ 1.3	65.3 $\pm$ 0.9	66.3 $\pm$ 1.2	64.6 $\pm$ 0.8
Median [16]	60.1 $\pm$ 0.4	57.3 $\pm$ 0.1	53.6 $\pm$ 2.0	87.4 $\pm$ 0.3	86.0 $\pm$ 0.5	74.4 $\pm$ 5.5	86.2 $\pm$ 0.2	84.0 $\pm$ 0.2	79.9 $\pm$ 1.5	65.0 $\pm$ 1.2	65.6 $\pm$ 0.6	64.7 $\pm$ 1.1
Multi-Krum [15]	59.8 $\pm$ 0.2	58.1 $\pm$ 1.3	55.1 $\pm$ 4.4	87.6 $\pm$ 0.3	87.9 $\pm$ 0.3	80.1 $\pm$ 7.9	85.9 $\pm$ 0.2	84.9 $\pm$ 0.1	81.4 $\pm$ 3.3	64.8 $\pm$ 0.4	65.1 $\pm$ 0.7	64.5 $\pm$ 0.7
Bulyan [21]	58.8 $\pm$ 0.5	57.0 $\pm$ 1.3	54.5 $\pm$ 3.4	87.3 $\pm$ 0.3	87.2 $\pm$ 0.4	77.4 $\pm$ 10.0	85.8 $\pm$ 0.3	84.5 $\pm$ 0.3	81.8 $\pm$ 2.9	64.6 $\pm$ 0.2	63.9 $\pm$ 0.7	63.1 $\pm$ 0.4
Geo-median / RFA [22]	60.7 $\pm$ 0.4	57.7 $\pm$ 1.0	54.5 $\pm$ 1.8	87.6 $\pm$ 0.4	86.5 $\pm$ 0.7	72.0 $\pm$ 6.3	86.3 $\pm$ 0.1	83.9 $\pm$ 0.3	79.6 $\pm$ 1.3	65.3 $\pm$ 1.3	65.8 $\pm$ 0.7	64.8 $\pm$ 0.3
FLTrust [12]	50.7 $\pm$ 2.9	50.1 $\pm$ 1.0	50.4 $\pm$ 1.6	84.5 $\pm$ 1.9	85.3 $\pm$ 1.9	86.0 $\pm$ 0.9	83.5 $\pm$ 1.2	83.8 $\pm$ 0.6	79.8 $\pm$ 3.0	63.7 $\pm$ 0.3	62.4 $\pm$ 0.4	63.4 $\pm$ 1.0
FedGT [20]	55.8 $\pm$ 2.1	50.2 $\pm$ 8.2	50.3 $\pm$ 5.9	87.7 $\pm$ 0.4	87.7 $\pm$ 0.7	82.1 $\pm$ 2.3	85.7 $\pm$ 0.0	84.9 $\pm$ 0.6	80.7 $\pm$ 1.3	63.5 $\pm$ 0.6	65.0 $\pm$ 0.5	64.3 $\pm$ 0.6
CB-SAFE+ (ours)	60.6 $\pm$ 0.3	59.0 $\pm$ 0.3	56.5 $\pm$ 1.3	87.9 $\pm$ 0.4	88.0 $\pm$ 0.3	87.0 $\pm$ 0.8	86.7 $\pm$ 0.1	86.3 $\pm$ 0.2	86.4 $\pm$ 0.2	65.3 $\pm$ 0.5	64.3 $\pm$ 0.2	63.3 $\pm$ 0.9

TABLE VII

DUTY-CYCLED ATTACKER (CIFAR-10 SIGN-FLIP, $\gamma=5$, $f=0.2$; 3 SEEDS, 50 ROUNDS): A CLIENT POISONS A FRACTION δ OF ROUNDS ($\delta=1$: ALWAYS ON); EXCLUSION BY THE ADAPTIVE-GAP SUSPICION RULE (Eq. 8).

Attacker duty δ	Test acc. (%)	Attackers excl. (of 6)
Clean (no attack)	59.0	—
0.50	59.8 $\pm$ 0.5	1.7
0.70	59.0 $\pm$ 0.5	5.3
0.80	59.1 $\pm$ 1.0	6.0
0.84	57.7 $\pm$ 1.6	6.0
0.90	57.1 $\pm$ 2.4	5.7
1.00 (always-on)	57.5 $\pm$ 1.6	6.0

evades most exclusions (1.7 of 6 at $\delta=0.5$), but the attack is then too weak to matter (59.8%, at the clean baseline); once $\delta \geq 0.7$ the accumulated suspicion catches essentially all six (5.3–6.0 of 6). The duty-cycler thus faces a no-win trade-off: raise δ and it is caught; lower it and the attack is correspondingly weaker. A stronger threshold-aware adversary that jointly minimizes footprint and detectability remains open, but the naive duty-cycle evasion does not succeed.

I. Ablation of CB-SAFE+ Components

CB-SAFE+ layers three ingredients on top of clustered secure aggregation: temporal reputation, temporally-overlapping re-randomized groups, and a windowed COMP decode. Table VIII isolates each under the identical sign-flip protocol. The base temporal reputation (ov1) restores learning at moderate contamination and holds 53.6% at $f=0.3$ on CIFAR-10; spreading the tests over $o=4$ overlapping rounds (ov4) lifts this to 57.7%, and the full hybrid is comparable at 57.4%, all far above FedGT’s actual BCJR decoder, which collapses to chance at this contamination (Table IV). The decisive gain is the temporal overlap; the windowed COMP decode, which counts a client only when it is flagged across the whole window, mainly suppresses honest false positives rather than adding accuracy. Both gains are concentrated on CIFAR-10, the hardest split: on FashionMNIST, EMNIST, and Edge-IIoTset the three variants agree within 0.3 points, where the base temporal reputation already suffices, so the overlap and windowed decode earn their keep specifically in the high- f , hard-task regime where laundering bites. The trust-free variant,

which uses *no* root dataset, matches the others at $f=0.1$ but collapses beyond it: attacker identification without any trusted anchor is possible only in the low-contamination regime, a capability boundary of trust-free identification.

J. Sensitivity to the Detector Thresholds

CB-SAFE+’s detector has three hand-set constants: the loss-probe flag margin δ , the minimum suspicion gap that counts as a real separation, and the floor a flagged group must exceed before exclusion. A margin stated in absolute cross-entropy units that works unchanged across four datasets invites the question of whether it was fitted to them, so we sweep each over five values around its operating point, three seeds at 50 rounds, on CIFAR-10 sign-flip at $f=0.2$ — the configuration where the components separate at all (Table VIII):

Threshold	setting: accuracy (%)				
δ (flag margin)	.10:58.9	.15:58.7	.25:59.0	.40:57.3	.60:53.7
suspicion gap	.05:59.4	.10:59.3	.15:59.2	.25:58.9	.35:58.4
exclusion floor	.10:59.5	.20:59.3	.25:59.3	.35:59.3	.50:58.8

Bold marks the value used throughout the paper. Two of the three knobs are close to inert: the suspicion gap spans 1.1 points across a sevenfold range and the exclusion floor 0.7 points across a fivefold one. The flag margin matters more (5.3 points), but asymmetrically — accuracy is flat from $\delta=0.10$ to 0.25 and falls only as δ grows past it, where the probe becomes too permissive to flag poisoned clusters at all. The operating point therefore sits on a plateau rather than at a peak, which is the signature one wants: had δ been fitted to these runs, the neighbouring settings would be worse, not equal.

One caveat on reading these against Table V. This sweep was run on a different GPU and PyTorch build than the CB-SAFE+ rows of the main tables, and the simulator does not pin cuDNN determinism, so the same configuration reproduces 59.0% here against the 57.5% reported there — a consistent +1.5-point offset across all three seeds. The sweep is internally consistent and should be read as a comparison among its own settings, not as a restatement of table values.

K. The Privacy–Robustness Trade-off

Fixing the rule (median) and sweeping cluster size traces the dial empirically (CIFAR-10 sign-flip, a 30-round median-only

TABLE VIII

ABLATION OF CB-SAFE+ COMPONENTS UNDER SIGN-FLIP (SAME PROTOCOL AS TABLE V). THE COMPONENTS SEPARATE ONLY ON CIFAR-10, THE HARDEST OF THE FOUR: THERE OVERLAPPING GROUPS AND THE HYBRID COMP DECODE ADD ROBUSTNESS AT HIGH f , WHILE ON FASHIONMNIST, EMNIST AND EDGE-IIOTSET THE THREE VARIANTS AGREE WITHIN 0.3 POINTS AND THE BASE RULE ALREADY SUFFICES. THE TRUST-FREE VARIANT USES NO ROOT DATASET BUT DEGRADES BEYOND $f=0.1$. BEST PER COLUMN IN BOLD.

Method	CIFAR-10			FashionMNIST			EMNIST			Edge-IIoTset		
	$f=.1$	$f=.2$	$f=.3$	$f=.1$	$f=.2$	$f=.3$	$f=.1$	$f=.2$	$f=.3$	$f=.1$	$f=.2$	$f=.3$
Base: temporal reputation (ov1)	61.1 $\pm$ 0.3	55.9 $\pm$ 1.8	53.6 $\pm$ 5.6	88.0 $\pm$ 0.4	88.0 $\pm$ 0.3	86.7 $\pm$ 1.0	86.7 $\pm$ 0.2	86.0 $\pm$ 0.2	86.3 $\pm$ 0.2	65.3 $\pm$ 0.4	65.1 $\pm$ 1.1	64.5 $\pm$ 0.7
+ overlapping groups (ov4)	60.4 $\pm$ 0.6	57.6 $\pm$ 1.6	57.7 $\pm$ 2.3	87.9 $\pm$ 0.4	88.0 $\pm$ 0.3	86.9 $\pm$ 0.8	86.7 $\pm$ 0.1	86.3 $\pm$ 0.1	86.5 $\pm$ 0.2	65.4 $\pm$ 0.5	65.2 $\pm$ 0.2	64.5 $\pm$ 0.8
+ hybrid COMP decode (full)	60.5 $\pm$ 0.5	57.5 $\pm$ 1.6	57.4 $\pm$ 1.8	87.9 $\pm$ 0.3	88.0 $\pm$ 0.4	86.9 $\pm$ 0.8	86.7 $\pm$ 0.2	86.4 $\pm$ 0.1	86.4 $\pm$ 0.2	65.4 $\pm$ 0.5	65.2 $\pm$ 0.2	64.5 $\pm$ 0.8
Trust-free (no root data)	61.4 $\pm$ 0.4	10.0 $\pm$ 0.0	10.0 $\pm$ 0.0	87.8 $\pm$ 0.3	10.0 $\pm$ 0.0	10.0 $\pm$ 0.0	86.8 $\pm$ 0.1	2.1 $\pm$ 0.0	2.1 $\pm$ 0.0	64.4 $\pm$ 0.3	45.2 $\pm$ 26.6	7.4 $\pm$ 0.2

sweep). Without privacy ($c=1$), the median degrades gently from 50% to 39% as f grows to 0.3, i.e., classical robust aggregation. At $c=3$ the same rule holds to $f=0.1$ (48%) and collapses beyond; at $c=5$ degradation begins already at $f=0.1$ (40%): the breakdown frontier shifts left exactly as $(1-f)^c$ predicts. Two further observations sharpen the picture. First, at $f=0.05$ privacy is *free*: $c=3$ matches or slightly exceeds $c=1$ (52% vs. 50%), because cluster averaging denoises before the median. Second, the dial's cost is refundable: at $c=3$, $f=0.3$, where the private median collapses to 10% against $\sim 39\%$ without privacy, CB-SAFE+ recovers comparable accuracy *while keeping the anonymity set*, by paying in rounds (warmup) rather than in privacy. Overlapping groups add further margin: the full detector at $o=4$ raises CIFAR $f=0.3$ from 53.6% ($o=1$) to 57.7% (Table VIII).

VI. SECURITY DISCUSSION AND LIMITATIONS

1) *Guarantees of the design*: Within a cluster, privacy reduces to the double-masking argument of [1] with the DH-style key agreement replaced by an IND-CCA2 KEM: masks are ChaCha20 outputs keyed by HKDF of encapsulated secrets, so an honest-but-curious server colluding with fewer than t cluster members learns only cluster sums. The robust layer never inspects anything finer than a cluster mean.

2) *Limits of the guarantee*: We do not claim security against an actively malicious server (who could misreport dropouts; standard mitigations apply), nor differential privacy on the cluster sums themselves; the anonymity set is bounded by the alive cluster size, and cluster sums of very small clusters leak more than full-cohort sums. Robustness degrades predictably as $k(1-f)^c$ approaches the trim capacity: at $c=3$, $f=0.3$ leaves an expected 3.4 clean clusters of 10, near the breakdown of a 2-per-side trimmed mean; this is the price of the anonymity set. HQC operations are $\sim 100\text{--}600\times$ slower than ML-KEM's depending on the operation, which is immaterial here (setup-only) but would matter for protocols that encapsulate per round.

VII. CONCLUSION

CB-SAFE positions cryptographic diversity as a configuration choice rather than a research programme: the KEM sits behind one interface, and the measured cost of choosing the code-based occupant is a one-time setup constant. The more consequential finding is what secure aggregation does to robustness: cluster averaging does not merely dilute poisoning,

it *launders* it, transforming conspicuous attacks into plausible-looking sums that defeat exactly the rules practitioners would reach for. Defending therefore requires signals that survive aggregation (direction, loss) accumulated over time. CB-SAFE+ shows one such design that identifies individual attackers from group observations without spending any privacy. The open questions our results make concrete: targeted backdoors remain invisible to sum-level probes at every malicious fraction we tested, an actively malicious server is outside our threat model, and while a naive duty-cycled attacker does not evade the temporal test (Table VII), a threshold-aware adversary that jointly minimizes its footprint and detectability remains the natural next step. The implementation and all measurement scripts are released open-source as a reference point for KEM-level cryptographic diversity in post-quantum secure aggregation for FL.

REFERENCES

- [1] K. Bonawitz *et al.*, "Practical secure aggregation for privacy-preserving machine learning," in *Proc. ACM CCS*, 2017, pp. 1175–1191.
- [2] National Institute of Standards and Technology, "Status report on the fourth round of the NIST post-quantum cryptography standardization process," NIST IR 8545, Mar. 2025.
- [3] National Institute of Standards and Technology, "Module-lattice-based key-encapsulation mechanism standard," FIPS 203, Aug. 2024.
- [4] X. Zhang, H. Deng, R. Wu, J. Ren, and Y. Ren, "PQSF: Post-quantum secure privacy-preserving federated learning," *Sci. Rep.*, vol. 14, Art. no. 23553, 2024.
- [5] X. Qin and R. Xu, "Efficient post-quantum cross-silo federated learning based on key homomorphic pseudo-random function," *Mathematics*, vol. 13, no. 9, Art. no. 1404, 2025.
- [6] P. Narsimhulu, P. Chithaluru, and R. Aluvalu, "Efficient post-quantum cryptographic signature aggregation for low-latency distributed networks," *EURASIP J. Inf. Secur.*, vol. 2026, Art. no. 6, 2026.
- [7] M. Rahmati and N. Rahmati, "Byzantine-robust federated learning framework with post-quantum secure aggregation for real-time threat intelligence sharing in critical IoT infrastructure," arXiv:2601.01053, 2026.
- [8] A. Nath and H. Kasyap, "CQSA: Byzantine-robust clustered quantum secure aggregation in federated learning," in *Proc. Int. Workshop Secure Efficient Federated Learning (FL@ACM CCS)*, 2026.
- [9] "Post-quantum secure aggregation via code-based homomorphic encryption," arXiv:2601.13031, 2026.
- [10] C. L. Chan, P. H. Che, S. Jaggi, and V. Saligrama, "Non-adaptive probabilistic group testing with noisy measurements: Near-optimal bounds with efficient algorithms," in *Proc. 49th Annu. Allerton Conf. Commun., Control, Comput.*, 2011, pp. 1832–1839.
- [11] J. Singh, P. Singh, A. Kaur, and M. Hedabou, "Post-quantum secure fog-edge computing using federated learning with blockchain," *J. Super-comput.*, vol. 81, Art. no. 1249, 2025.
- [12] X. Cao, M. Fang, J. Liu, and N. Z. Gong, "FLTrust: Byzantine-robust federated learning via trust bootstrapping," in *Proc. NDSS*, 2021.
- [13] C. Xie, S. Koyejo, and I. Gupta, "Zeno: Distributed stochastic gradient descent with suspicion-based fault-tolerance," in *Proc. ICML*, 2019.

- [14] J. H. Bell, K. A. Bonawitz, A. Gascón, T. Lepoint, and M. Raykova, "Secure single-server aggregation with (poly)logarithmic overhead," in *Proc. ACM CCS*, 2020, pp. 1253–1269.
- [15] P. Blanchard, E. M. El Mhamdi, R. Guerraoui, and J. Stainer, "Machine learning with adversaries: Byzantine tolerant gradient descent," in *Proc. NeurIPS*, 2017, pp. 119–129.
- [16] D. Yin, Y. Chen, R. Kannan, and P. Bartlett, "Byzantine-robust distributed learning: Towards optimal statistical rates," in *Proc. ICML*, 2018, pp. 5650–5659.
- [17] E. Bagdasaryan, A. Veit, Y. Hua, D. Estrin, and V. Shmatikov, "How to backdoor federated learning," in *Proc. AISTATS*, 2020, pp. 2938–2948.
- [18] J. So, B. Güler, and A. S. Avestimehr, "Byzantine-resilient secure federated learning," *IEEE J. Sel. Areas Commun.*, vol. 39, no. 7, pp. 2168–2181, 2021.
- [19] H. Nguyen, S. Huda, Y. Nogami, and T. T. Nguyen, "Security in post-quantum era: A comprehensive survey on lattice-based algorithms," *IEEE Access*, vol. 13, pp. 89003–89024, 2025.
- [20] M. Xhemrishi, J. Östman, A. Wachter-Zeh, and A. Graell i Amat, "FedGT: Identification of malicious clients in federated learning with secure aggregation," *IEEE Trans. Inf. Forensics Security*, vol. 20, pp. 2577–2592, 2025.
- [21] E. M. El Mhamdi, R. Guerraoui, and S. Rouault, "The hidden vulnerability of distributed learning in Byzantium," in *Proc. ICML*, 2018, pp. 3521–3530.
- [22] K. Pillutla, S. M. Kakade, and Z. Harchaoui, "Robust aggregation for federated learning," *IEEE Trans. Signal Process.*, vol. 70, pp. 1142–1154, 2022.
- [23] M. Fang, X. Cao, J. Jia, and N. Z. Gong, "Local model poisoning attacks to Byzantine-robust federated learning," in *Proc. USENIX Security*, 2020, pp. 1605–1622.
- [24] V. Shejwalkar and A. Houmansadr, "Manipulating the Byzantine: Optimizing model poisoning attacks and defenses for federated learning," in *Proc. NDSS*, 2021.
- [25] T. D. Nguyen *et al.*, "FLAME: Taming backdoors in federated learning," in *Proc. USENIX Security*, 2022, pp. 1415–1432.
- [26] B. McMahan, E. Moore, D. Ramage, S. Hampson, and B. A. y Arcas, "Communication-efficient learning of deep networks from decentralized data," in *Proc. AISTATS*, 2017, pp. 1273–1282.
- [27] P. Kairouz *et al.*, "Advances and open problems in federated learning," *Found. Trends Mach. Learn.*, vol. 14, no. 1–2, pp. 1–210, 2021.
- [28] L. Zhu, Z. Liu, and S. Han, "Deep leakage from gradients," in *Proc. NeurIPS*, 2019, pp. 14747–14756.
- [29] J. Geiping, H. Bauermeister, H. Dröge, and M. Moeller, "Inverting gradients: How easy is it to break privacy in federated learning?," in *Proc. NeurIPS*, 2020, pp. 16937–16947.
- [30] M. Fredrikson, S. Jha, and T. Ristenpart, "Model inversion attacks that exploit confidence information and basic countermeasures," in *Proc. ACM CCS*, 2015, pp. 1322–1333.
- [31] R. Shokri, M. Stronati, C. Song, and V. Shmatikov, "Membership inference attacks against machine learning models," in *Proc. IEEE Symp. Secur. Privacy*, 2017, pp. 3–18.
- [32] A. R. Elkordy, J. Zhang, Y. H. Ezzeldin, K. Psounis, and S. Avestimehr, "How much privacy does federated learning with secure aggregation guarantee?," *Proc. Privacy Enhancing Technol.*, 2022, pp. 510–526.
- [33] J. So *et al.*, "LightSecAgg: A lightweight and versatile design for secure aggregation in federated learning," in *Proc. MLSys*, 2022, pp. 694–720.
- [34] T. Jahani-Nezhad, M. A. Maddah-Ali, S. Li, and G. Caire, "SwiftAgg: Communication-efficient and dropout-resistant secure aggregation for federated learning with worst-case security guarantees," in *Proc. IEEE ISIT*, 2022, pp. 103–108.
- [35] P. W. Shor, "Polynomial-time algorithms for prime factorization and discrete logarithms on a quantum computer," *SIAM J. Comput.*, vol. 26, no. 5, pp. 1484–1509, 1997.
- [36] R. J. McEliece, "A public-key cryptosystem based on algebraic coding theory," *JPL Deep Space Netw. Prog. Rep.*, pp. 114–116, 1978.
- [37] F. J. MacWilliams and N. J. A. Sloane, *The Theory of Error-Correcting Codes*. Amsterdam, The Netherlands: North-Holland, 1977.
- [38] National Institute of Standards and Technology, "Module-lattice-based digital signature standard," FIPS 204, Aug. 2024.
- [39] G. Baruch, M. Baruch, and Y. Goldberg, "A little is enough: Circumventing defenses for distributed learning," in *Proc. NeurIPS*, 2019, pp. 8635–8645.
- [40] H. Wang *et al.*, "Attack of the tails: Yes, you really can backdoor federated learning," in *Proc. NeurIPS*, 2020, pp. 16070–16084.
- [41] V. Tolpegin, S. Truex, M. E. Gursoy, and L. Liu, "Data poisoning attacks against federated learning systems," in *Proc. ESORICS*, 2020, pp. 480–501.
- [42] Z. Zhang, X. Cao, J. Jia, and N. Z. Gong, "FLDetector: Defending federated learning against model poisoning attacks via detecting malicious clients," in *Proc. ACM KDD*, 2022, pp. 2545–2555.
- [43] R. Dorfman, "The detection of defective members of large populations," *Ann. Math. Stat.*, vol. 14, no. 4, pp. 436–440, 1943.
- [44] M. Aldridge, O. Johnson, and J. Scarlett, "Group testing: An information theory perspective," *Found. Trends Commun. Inf. Theory*, vol. 15, no. 3–4, pp. 196–392, 2019.
- [45] A. Krizhevsky, "Learning multiple layers of features from tiny images," Univ. Toronto, Tech. Rep., 2009.
- [46] H. Xiao, K. Rasul, and R. Vollgraf, "Fashion-MNIST: A novel image dataset for benchmarking machine learning algorithms," arXiv:1708.07747, 2017.
- [47] G. Cohen, S. Afshar, J. Tapson, and A. van Schaik, "EMNIST: Extending MNIST to handwritten letters," in *Proc. IJCNN*, 2017, pp. 2921–2926.
- [48] M. A. Ferrag, O. Friha, D. Hamouda, L. Maglaras, and H. Janicke, "Edge-IIoTset: A new comprehensive realistic cyber security dataset of IoT and IIoT applications for centralized and federated learning," *IEEE Access*, vol. 10, pp. 40281–40306, 2022.
- [49] T.-M. H. Hsu, H. Qi, and M. Brown, "Measuring the effects of non-identical data distribution for federated visual classification," arXiv:1909.06335, 2019.
- [50] S. Hou, S. Li, T. Jahani-Nezhad, and G. Caire, "PriRoAgg: Achieving robust model aggregation with minimum privacy leakage for federated learning," *IEEE Trans. Inf. Forensics Security*, 2024.
- [51] O. Touat, C. Sabater, M. Maouche, and S. Ben Mokhtar, "Giskard: Byzantine robust and confidential aggregation for large-scale decentralized learning," arXiv:2606.19129, 2026.
- [52] E. Mármol Campos, A. González Vidal, J. L. Hernández Ramos, and A. Skarmeta, "FLAegis: A two-layer defense framework for federated learning against poisoning attacks," arXiv:2508.18737, 2025.
- [53] Z. Dou, J. Wang, W. Sun, Z. Liu, and M. Fang, "Toward malicious clients detection in federated learning," arXiv:2505.09110, 2025.
- [54] D. K. Bhaskar, B. Minimol, and V. P. Binu, "Robust federated learning for malicious clients using loss trend deviation detection," arXiv:2601.20915, 2026.
- [55] Y. Ma, J. Woods, S. Angel, A. Polychroniadou, and T. Rabin, "Flamingo: Multi-round single-server secure aggregation with applications to private federated learning," in *Proc. IEEE Symp. Security and Privacy (S&P)*, 2023, pp. 477–496.
- [56] H. Lycklama, L. Burkhalter, A. Viand, N. Küchler, and A. Hithnawi, "RoFL: Robustness of secure federated learning," in *Proc. IEEE Symp. Security and Privacy (S&P)*, 2023, pp. 453–476.
- [57] A. Roy Chowdhury, C. Guo, S. Jha, and L. van der Maaten, "EIFFeL: Ensuring integrity for federated learning," in *Proc. ACM CCS*, 2022, pp. 2535–2549.
- [58] M. Rathee, C. Shen, S. Wagh, and R. A. Popa, "ELSA: Secure aggregation for federated learning with malicious actors," in *Proc. IEEE Symp. Security and Privacy (S&P)*, 2023, pp. 1961–1979.
- [59] C. Aguilar Melchor, N. Aragon, S. Bettaieb, L. Bidoux, O. Blazy, J.-C. Deneuville, P. Gaborit, E. Persichetti, and G. Zémor, "HQC: Hamming Quasi-Cyclic," NIST Post-Quantum Cryptography Standardization, Round-4 submission, 2023.
- [60] A. Shamir, "How to share a secret," *Commun. ACM*, vol. 22, no. 11, pp. 612–613, 1979.
- [61] D. J. Bernstein, "ChaCha, a variant of Salsa20," in *Workshop Record of SASC*, 2008.
- [62] H. Krawczyk, "Cryptographic extraction and key derivation: The HKDF scheme," in *Proc. CRYPTO*, 2010, pp. 631–648.
- [63] L. R. Bahl, J. Cocke, F. Jelinek, and J. Raviv, "Optimal decoding of linear codes for minimizing symbol error rate," *IEEE Trans. Inf. Theory*, vol. 20, no. 2, pp. 284–287, 1974.